

Segurança da Informação e Privacidade



***Responsabilidade não delegável:
Pessoa, a “camada” mais
importante da Segurança da
Informação***



Apresentadora
Susan Rossi



Objetivos da aula



- Gerar consciência de que segurança da informação é responsabilidade de todos, independente de cargo.
- Compreensão que cada colaborador é uma camada crítica de proteção de dados corporativos, de cliente e parceiros.
- Reconhecer que uma única ação inadequada pode anular investimentos milionários em segurança, compliance e governança.

Ao final da aula, cada participante terá critérios para tomar decisões éticas para a segurança das informações no trabalho.



Abertura



"Se eu investir R\$ 10 milhões em segurança, contratando os melhores especialistas, implementando MFA, DLP, EDR, SIEM e Zero Trust, mas um colaborador exportar uma base de clientes para o Excel e enviar por e-mail pessoal ou ele apenas tirar uma foto da tela e enviar pelo whatsapp... quanto valeram os meus R\$ 10 milhões investidos?"

MFA (Multi-Factor Authentication) – Múltiplo fator de autenticação
DLP (Data Loss Prevention) – Prevenção de Perda de Dados
EDR (Endpoint Detection and Response) – Detecção e Resposta de Ponto de Extremidade
SIEM (Security Information and Event Management) – Sistema de Gerenciamento de Eventos e Informações de Segurança
Zero Trust - Confiança Zero



Segurança não é um produto Segurança é COMPORTAMENTO.

E ele começa no momento em que você
decide fazer o que é CERTO.



Conceito Aplicado



A Segurança da Informação é a prática de proteger dados contra acesso, uso, alteração, interrupção ou destruição não autorizados.

A base da área é estruturada em pilares fundamentais conhecidos pela sigla CID (ou tríade CIA em inglês):

Confidencialidade (Confidentiality)

→ Garante que a informação seja acessível apenas a pessoas ou sistemas previamente autorizados.

Exemplo: Criptografia e senhas fortes

Integridade (Integrity)

→ Assegura que os dados sejam precisos e não sejam modificados, corrompidos ou apagados.

Exemplo: Assinaturas digitais

Disponibilidade (Availability)

→ Garante que as informações e sistemas estejam sempre acessíveis e utilizáveis.

Exemplo: Redundância de servidores e backups

Você sabia?



95 % dos incidentes de segurança possuem algum componente Humano.

Não necessariamente é má-fé.
Às vezes é distração.
Às vezes pressa.
Às vezes excesso de confiança.



Casos Reais de Vazamentos de Dados

2022 – Uber

→ O que aconteceu:

Ataque iniciado por engenharia social. O invasor comprou dados vazados de um funcionario na dark web, e depois contatou o funcionario, fingindo ser membro da equipe de segurança da Uber, pediu que o funcionario aprovasse as autenticações MFA enviadas para seu celular. Quando ele conseguiu o acesso, ele acessou a conta Slack do colaborador e informou a toda a empresa sua façanha.

Impacto

- Acesso interno amplo, acesos a VPN, Scripts com credenciais de usuário administrador
- Exposição de sistemas críticos como a AWS e G Suite

Reflexão

→ MFA não protege contra alguém convencido a apertar o “Aprovar”, questione, analise, não faça algo só porque alguém mandou.

Casos Reais de Vazamentos de Dados



2023 – TSMC – Taiwan Semiconductor Manufacturing Company
É a maior fundição independente de semicondutores do mundo.

→ O que aconteceu:

Uma empresa fornecedora da TSMC foi comprometida por criminosos. Documentos internos foram vazados. Foi exigido resgate milionário.

O que falhou?

→ A fábrica não foi atacada diretamente. O fornecedor foi.

Reflexão

→ A segurança da informação não termina no portão da fábrica. Ela se estende para fornecedores, parceiros e clientes (pessoas).

[Fonte: Axios](#)

Casos Reais de Vazamentos de Dados

2026 – Meta / Instagram AI Chatbot

→ O que aconteceu:

*Pesquisadores demonstraram que um chatbot de suporte poderia ser manipulado através de técnicas de **Prompt Injection**, permitindo que invasores realizassem redefinições de credenciais sem validação adequada de identidade.*

Impacto

- Exposição de contas de alto perfil
- Questionamento público sobre segurança em Soluções em IA
- Queda de confiança em automações críticas e pressão de investidores sobre a Meta

Reflexão

→ A responsabilidade continua sendo humana. Mesmo que a decisão seja automatizada, alguém decidiu como aquela automação funcionaria e não validou o resultado.

Casos Reais de Vazamentos de Dados



2026 – INSS / Dataprev

→ O que aconteceu:

Em abril ocorreu um incidente de segurança envolvendo bases de dados do Instituto Nacional do Seguro Social (INSS), foi confirmado que aproximadamente 2.8 milhões de CPFs tiveram informações expostas. Embora cerca de 98% dos registros fossem de pessoas falecidas, aproximadamente 52 mil segurados vivos tiveram seus dados acessados indevidamente.

Impacto

- Para a organização: Investigação, necessidade de comunicação pública, custos de resposta ao incidente e impacto reputacional
- Para os cidadãos: Possibilidade de fraudes em seus CPFs, tentativas de engenharia social com golpes direcionados, exposição de informações pessoais

Reflexão

- Alguém autorizou, acessou, exportou, compartilhou ou não monitorou o que deveria estar olhando.

Checklist de Segurança – Versão “Fit”



Antes de acessar qualquer informação, reflita:

“Ter acesso não significa ter autorização para usar”

- Estou autorizado a acessar esse ambiente/dado?
- Estou acessando o ambiente correto? (VPN de Produção, homologação, teste)?
- Estou utilizando as minhas credenciais?
- Minha sessão está protegida por MFA?



Checklist de Segurança – Versão “Fit”



Antes de compartilhar qualquer informação, reflita:

“Se você não colocaria essa informação em um outdoor da cidade, não envie pelo whatapp”

- O grupo é corporativo e autorizado para compartilhamentos?
- O conteúdo contém dados pessoais ou de cliente?
- O conteúdo contém informações financeiras?
- O conteúdo contém prints de sistemas?
- Dados reais foram anonimizados e removidas credencias?
- Estou seguindo as políticas corporativas?



Checklist de Segurança – Versão “Fit”



Antes de compartilhar qualquer informação, reflita:

“Urgência é uma das armas preferidas dos golpistas”

- Confirmei a identidade do solicitante, validei por outro canal?
- O pedido que me fez, faz sentido para a função da pessoa?
- Estou sendo pressionado por urgência para eu não ter tempo de validar as informações do solicitante e o solicitado?
- Por que essa solicitação veio por esse meio de comunicação e desta forma?



Checklist de Segurança - – Versão “Fit”



Antes de utilizar qualquer ferramenta, reflita:
“Estou seguindo as políticas corporativas?”

- A ferramenta onde vou colocar informações, foi aprovada pela empresa?
- Não estou enviando dados e credenciais de clientes?
- Estou utilizando todas as configurações de segurança da informação ativadas na ferramenta?
- Não estou enviando código-fonte sensível?



Na Dúvida – Use a Regra:

**S
T
O
P**

- **S – Sensitive**
Contém informação sensível?
- **T - Trust**
Confio na origem e no destino?
- **O – Official**
Estou usando canais oficiais?
- **P – Permission**
Tenho autorização para fazer isso?



LGPD — Lei Geral de Proteção de Dados Pessoais



O dado não é da empresa. A empresa apenas recebeu a responsabilidade de protegê-lo.

→ O que é?

É a legislação brasileira que regula como empresas e órgãos públicos podem coletar, armazenar e usar informações pessoais. Seu objetivo principal é proteger a sua privacidade e garantir que você tenha controle dos seus dados.

Dados Pessoais e Sensíveis

- Nome, RG, CPF, Data de Nascimento, Endereço, E-mail e Telefone.
- Dados de Saúde, Religião, vida sexual, e biometria.

ANPD – Agência Nacional de Proteção de Dados

→ É a agência reguladora federal responsável por implementar e fiscalizar o cumprimento da LGPD em todo o Brasil, advertindo e aplicando multas em caso de vazamentos ou mau uso dos dados. Curiosidade: A multa é de 2% do faturamento da empresa, limitada a 50 milhões por infração.

Segurança não falha quando um Sistema é atacado.

Segurança falha quando uma **REGRA** deixa de ser seguida.



Pode ou Não Pode?

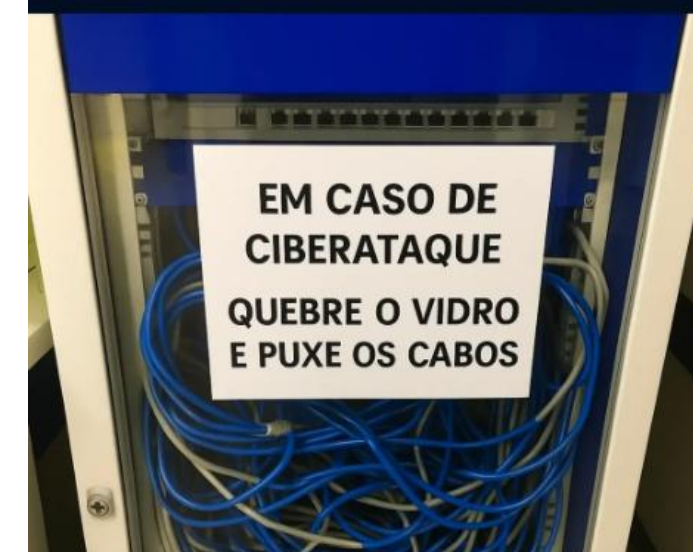
- Tirar print do Sistema e enviar no WhatsApp do colega?
- Utilizar dados reais em ambiente de teste?
- Compartilhar senha por que o colega entrou de férias?
- Reportar um erro que você mesmo causou?

O erro não reportado é muito mais perigoso que o erro cometido.

Há quanto tempo você não muda a sua senha?



Empresa: Temos um plano para todos os ciberataques.



QUANDO VOCÊ USA A MESMA SENHA EM TODAS AS CONTAS



Expectativa:



Realidade:



Quem é responsável pela Segurança da Informação?



- Equipe da TI?
- Equipe de Segurança?
- Equipe de Compliance?
- Equipe de Auditoria?
- Equipe da Diretoria?

TODOS são responsáveis.

A equipe de segurança cria as regras, a tecnologia cria as barreiras, mas quem protege a informação todos os dias é quem está sentado na cadeira.



Vamos de Boas Práticas



Boas Prática Pessoais

- Nunca compartilhe suas credencias, mesmo que seja com o “brother top” que te chama pro churras.
- Sempre utilize MFA e nunca aprove solicitações de MFA que não foram solicitadas por você.
- Utilize senhas exclusivas, troque com maior frequência e utilize cofres confiáveis de senhas, nada de usar senha mudar@123, e muito menos deixar anotado em post-it.
- Bloqueie sua estação de trabalho ao sair da frente da tela, você não quer pagar o churrasco do convite que enviou pra empresa inteira para irem a sua casa na próxima sexta-feira.

Boas Prática Corporativas

- Reporte qualquer suspeita de incidente imediatamente ao seu TI, mesmo que eles lhe olhem com intenção de perder o réu primário, é apenas sua impressão, eles são do bem.
- Bloqueie sua estação de trabalho ao sair da frente da tela, você não quer pagar o churrasco do convite que enviou pra empresa inteira para irem a sua casa na próxima sexta-feira.
- Utilize apenas softwares legais e autorizados, então para de instalar softwares de “limpeza de virus” no seu computador, nada de “clean isso”... “clean aquilo”, tenha um bom antivírus e o use.
- Mantenha atualizações dos sistemas sempre em dia, se o antivírus ou o windows avisar que tem atualização, atualize, e sim reinicie seu windows que está ativo a 658.428 dias.
- Evite WI-FI público, evite a ponto de usar os seus dados móveis, sério... EVITE.
- Efetue monitoramento dos resultados, use trilha de auditorias, comece no simples e aprimore. Lembre-se da LGPD (Lei Geral de Proteção de Dados Pessoais), você não gostaria de saber que seus dados estão expostos por ai para alguém usar de má fé, então cuide dos dados corporativos como se fossem os seus.

Vamos de Boas Práticas



Boas Prática Pessoais

- Reporte qualquer suspeita de incidente imediatamente ao seu TI, mesmo que eles lhe olhem com intenção de perder o réu primário, é apenas sua impressão, eles são do bem.
 - Bloqueie sua estação de trabalho ao sair da frente da tela, você não quer pagar o churrasco do convite que enviou pra empresa inteira para irem a sua casa na próxima sexta-feira.
 - Utilize apenas softwares legais e autorizados, então para de instalar softwares de “limpeza de virus” no seu computador, nada de “clean isso”... “clean aquilo”, tenha um bom antivírus e o use.
 - Mantenha atualizações dos sistemas sempre em dia, se o antivírus ou o windows avisar que tem atualização, atualize, e sim reinicie seu windows que está ativo a 658.428 dias.
 - Evite WI-FI público, evite a ponto de usar os seus dados móveis, sério... EVITE.
 - Efetue monitoramento dos resultados, use trilha de auditorias, comece no simples e aprimore.
- Lembre-se da LGPD (Lei Geral de Proteção de Dados Pessoais), você não gostaria de saber que seus dados estão expostos por aí para alguém usar de má fé, então cuide dos dados corporativos como se fossem os seus.

Fechamento

Tecnologia não assume
responsabilidade.

A **pessoa** continua sendo a “camada” mais importante da segurança da informação.



Auditoria não é
opcional

Monitoramento é
essencial

Informação e
aprendizado é potencial

Muito obrigado, pela atenção!



Telefone

+55 18 99741-0752



Email

contato@fmxsolucoes.com.br



LinkedIn

<https://www.linkedin.com/in/susan-rossi/>

Apresentadora
Susan Rossi

**QUANDO VOCÊ USA A MESMA
SENHA EM TODAS AS CONTAS**

